Féidearthachtaí as Cuimse
Infinite Possibilities

# Secure Communications & Cryptography (MACS H6014)

## Asymmetric Encryption & Key Exchange

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Asymmetric Encryption

- Probably the most significant advance in the 3000-year history of cryptography.
- Uses two keys – a **public** and a **private** key for secure communication.
- No need to secretly distribute keys, difficult to brute-force.
- Reuse of key does not significantly weaken security.
- A ***public key***, which may be known by anybody, and can be used to **encrypt messages**, and **verify signatures**.
- A ***private key***, known only to the recipient, is used to **decrypt messages** and **sign** (create) **signatures**.
- *More computationally intensive than symmetric cryptography*.



muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# How Asymmetric Encryption Works

## ❖ Key Pair Generation

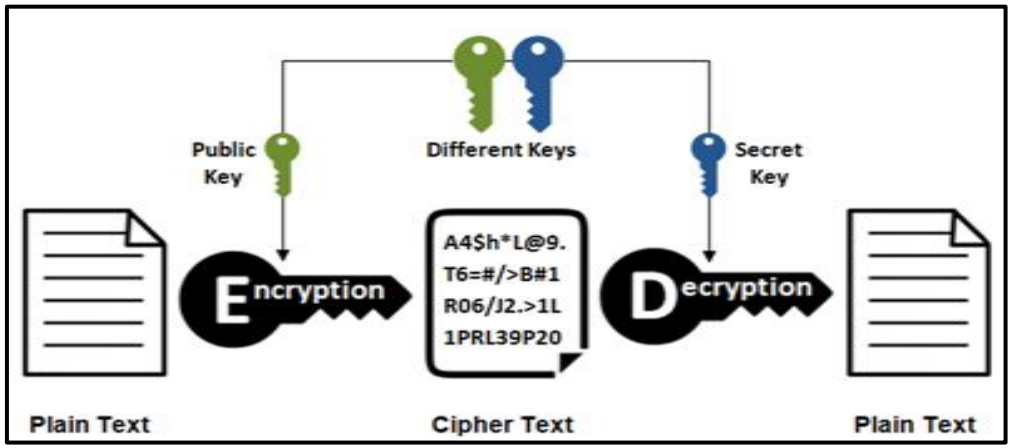
- A user or entity generates a key pair consisting of a public key and a private key.
- The public key is meant to be shared with anyone, while the private key must be kept secret.

## ❖ Encryption

- Send an encrypted message to the owner of the public key, and use the recipient's public key.
- The encryption algorithm takes the plaintext message and the recipient's public key and produces ciphertext.

## ❖ Decryption

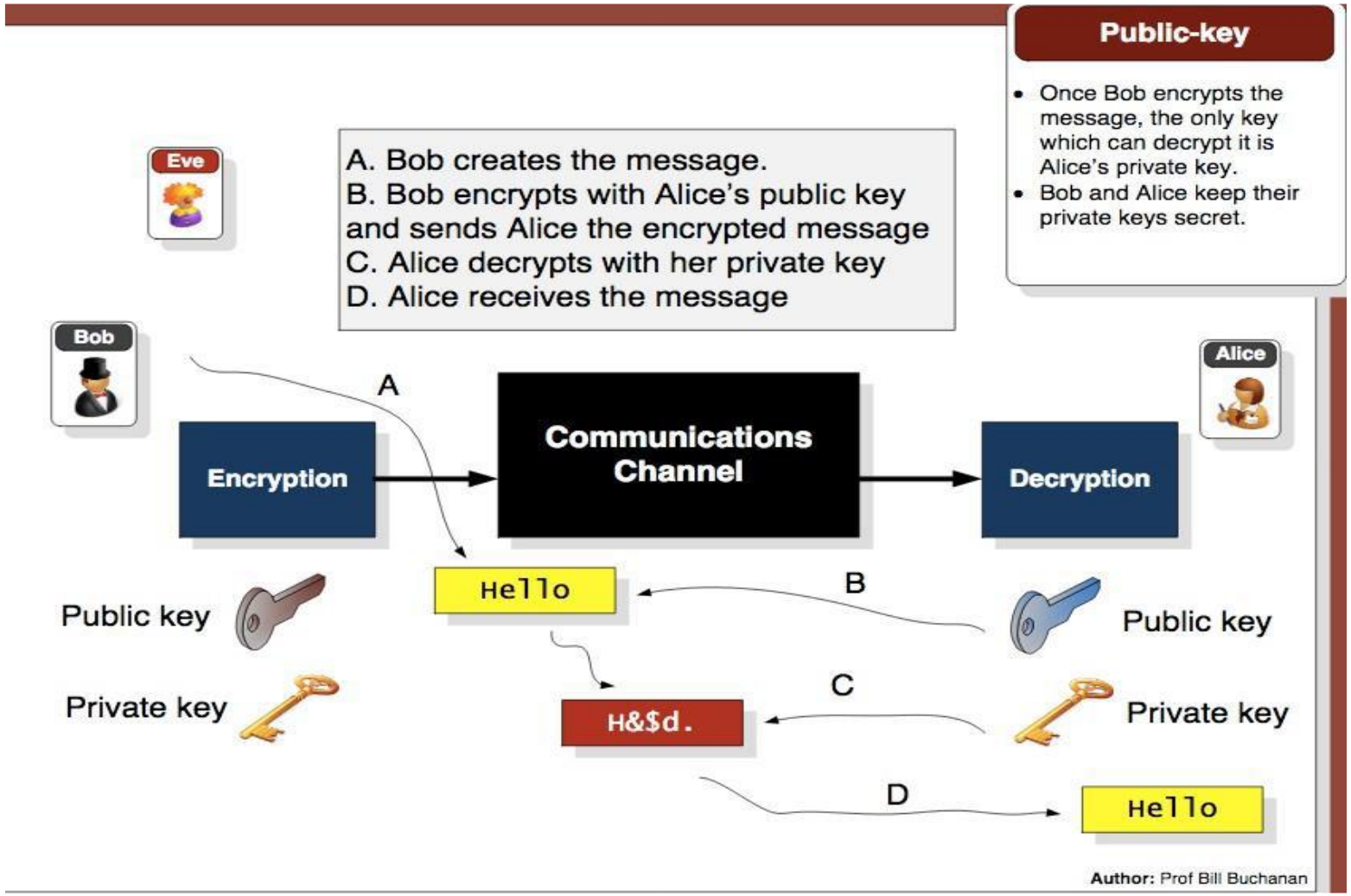
- Only the owner of the corresponding private key can decrypt the ciphertext.
- To decrypt the message, the recipient uses their private key and the decryption algorithm.
- The private key decrypts the ciphertext back into the original plaintext message.




muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Public Key

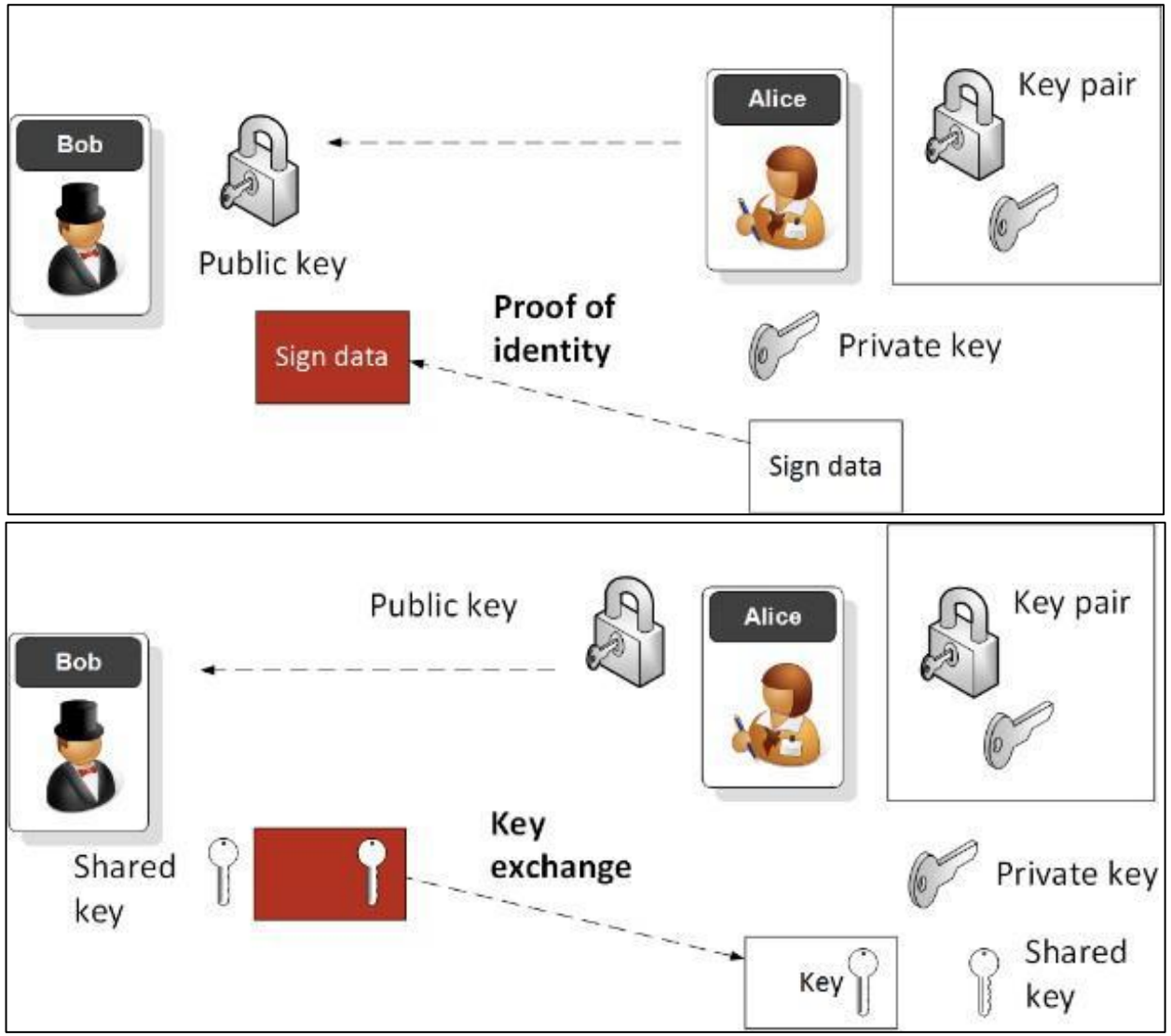



- **Public key encryption** is an asymmetric key method and uses two different keys: a **public key** (which can be distributed) and a **private key** (which must be kept secret).
- The public key is used to encrypt data that only the private key can decrypt **or vice-versa**.

muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Public Key (Contd.)




- We can use the public key encryption method for **identity checking:** i.e. Alice can prove her identity by using her ***private key to encrypt*** a value that can only be ***decrypted with her public key***.
- We can also use the public key encryption method for **symmetric key sharing**: i.e. Bob encrypts the ***shared key*** with the ***public key of the destination (Alice)*** which can only be read by using the ***private key (of Alice)***.

muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

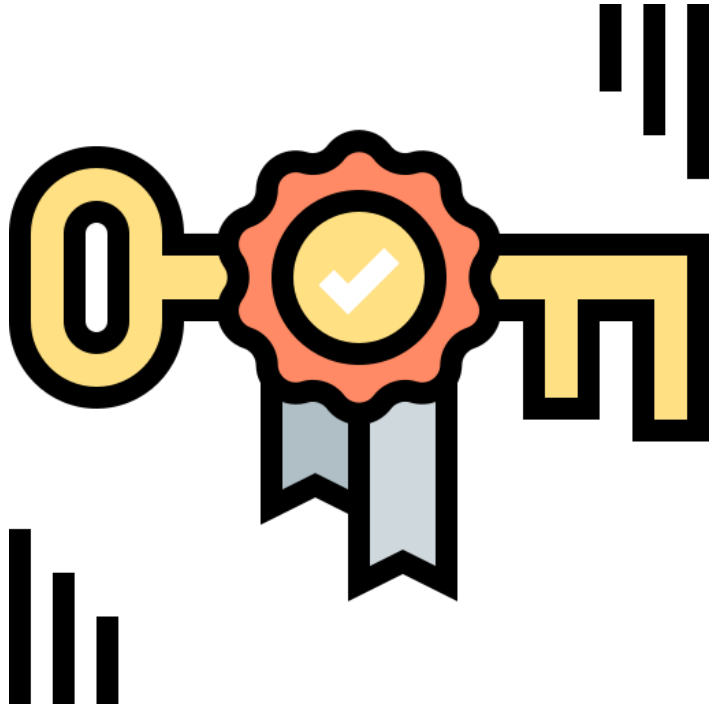
# How Does the Public Key Method Working

- It should be extremely difficult to determine the private key if given the public key.
- Three main methods are used for this:
- Integer factorization such as using large prime numbers

  (RSA Used with Digital Certs/SSL)
- Elliptic Curve Relationships

  (Such as the Elliptic Curve. Used in Smart Cards, IoT, Tor, Bitcoins).
- Discrete Logarithms ($Y = G^x \bmod P$)

  (such as El Gamal.).



muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Properties and Advantages of Asymmetric Encryption

- **Security**
  - Higher level of security because the private key is kept secret and never shared.
  - Even if someone has access to the public key, they cannot easily decrypt the encrypted data without the private key.
- **Confidentiality**
  - Ensures the confidentiality of the data being transmitted.
  - The recipient with the private key can decrypt and access the original message.
- **Authentication**
  - Can also be used for authentication purposes.
  - Encrypting data with a private key.
  - The owner of the corresponding public key can decrypt and verify the sender's signature.
- **Digital Signature**
  - Create digital signatures, which can verify the authenticity and integrity of a message or document.
  - A sender can sign a message with their private key, and recipients can verify the signature using the sender's public key.

muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Protocols Use Asymmetric Key Algorithms

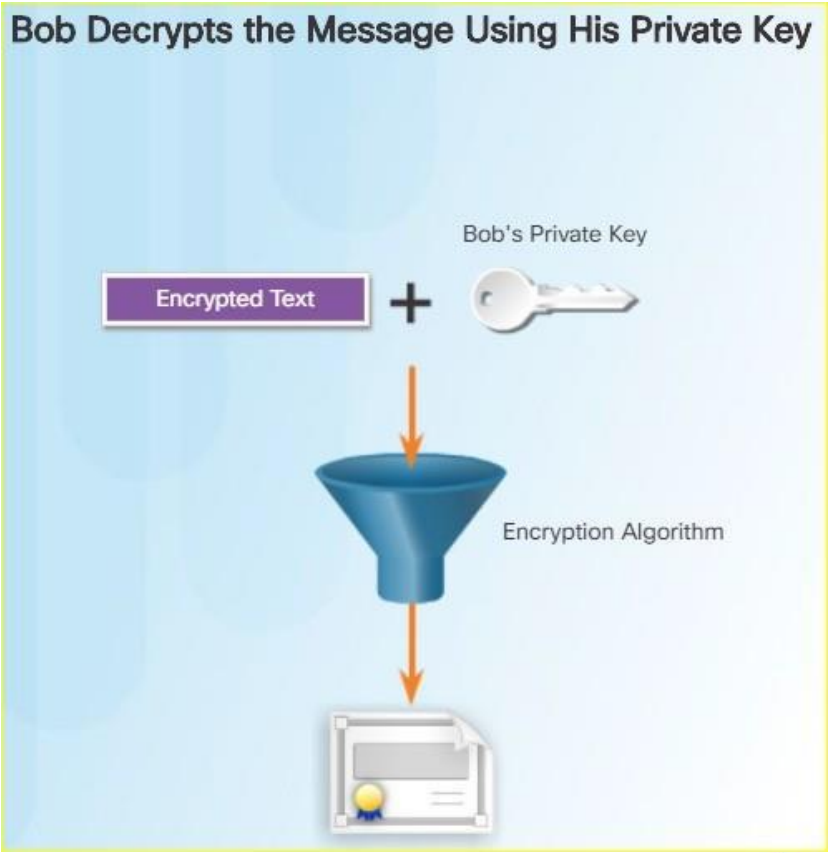
- **Internet Key Exchange (IKE)**
  - This is a fundamental component of IPSec VPNs.
  - IKE is a secure key management protocol that is used to set up a secure, authenticated communications channel between two devices.
- **Secure Socket Layer (SSL)**
  - This is now implemented as IETF standard TLS.
  - SSL is a security protocol that creates an encrypted link between a web server and a web browser.
- **Secure Shell (SSH)**
  - This is a protocol that provides a secure remote access connection to network devices.
  - SSH also refers to the suite of utilities that implement the SSH protocol.
- **Pretty Good Privacy (PGP)**
  - This is a computer program that provides cryptographic privacy and authentication. It is often used to increase the security of email communications.
  - It was one of the first freely available forms of public-key cryptography software.

muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Asymmetric Encryption - Confidentiality

- Asymmetric algorithms are used to provide confidentiality without pre-sharing a password.
- The confidentiality objective of asymmetric algorithms is initiated when the encryption process is started with the public key.
- The process can be summarized using the formula: **Public Key (Encrypt) + Private Key (Decrypt) = Confidentiality**
  - When the public key is used to encrypt the data, the private key must be used to decrypt the data.
  - Only one host has the private key.

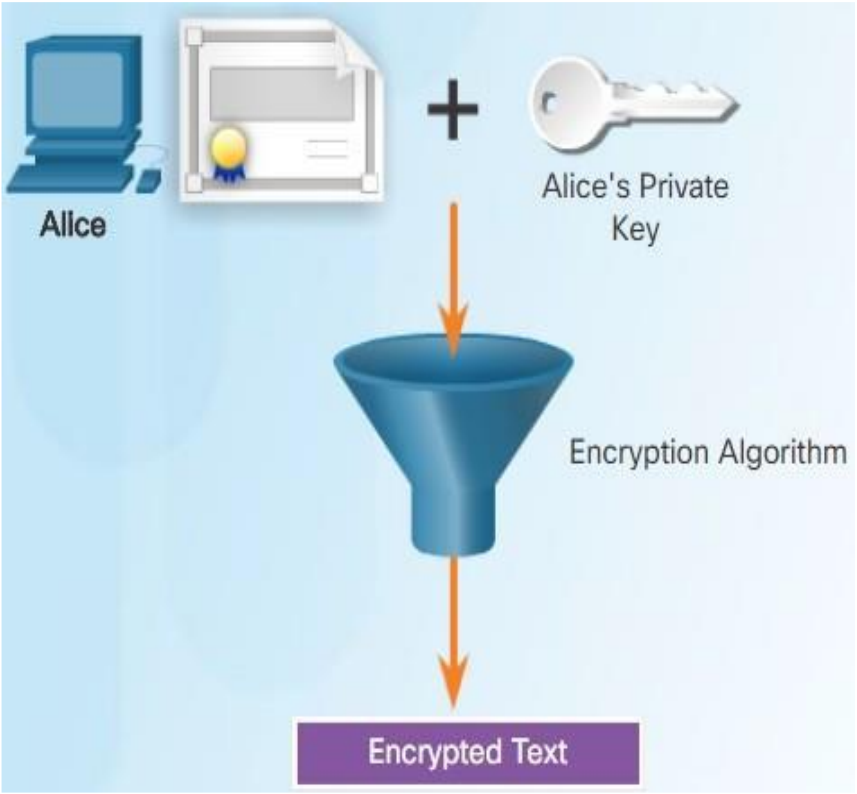



muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Asymmetric Encryption - Authentication

- The authentication objective of asymmetric algorithms is initiated with the private key encryption process.
- The process can be summarized using the formula: **Private Key (Encrypt) + Public Key (Decrypt) = Authentication**
- When the private key is used to encrypt the data, the corresponding public key must be used to decrypt the data.
- Because only one host has the private key, only that host could have encrypted the message, providing authentication of the sender.
- When a host successfully decrypts a message using a public key, it is trusted that the private key encrypts the message, which verifies the sender.

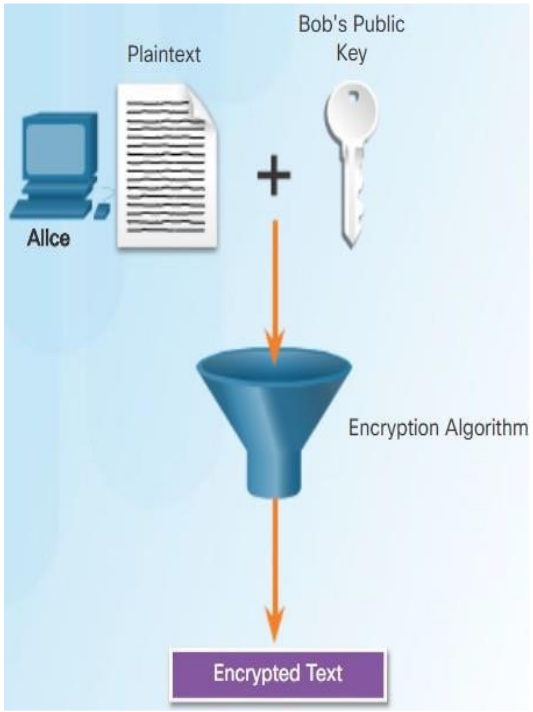


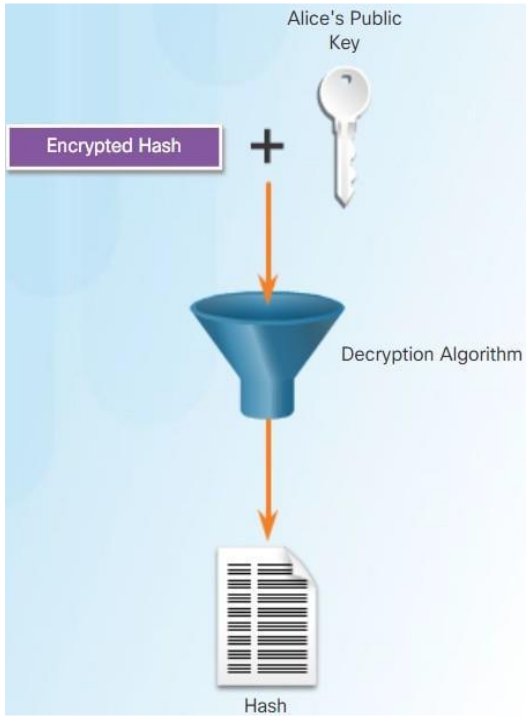

muhammad.arshad@tudublin.ie

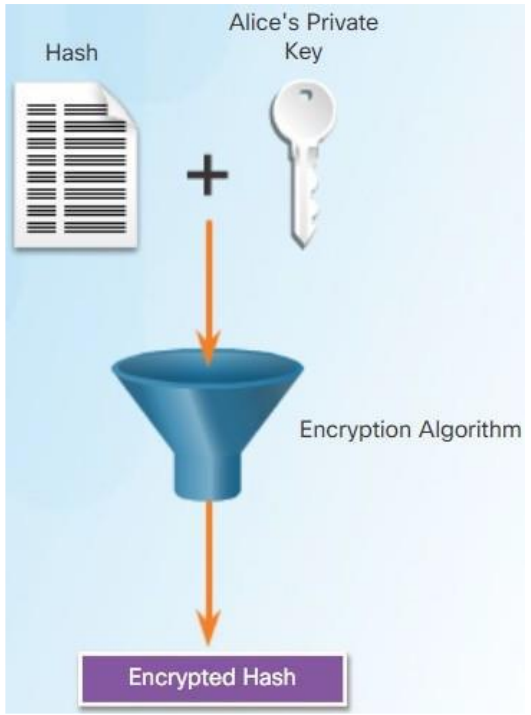
OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

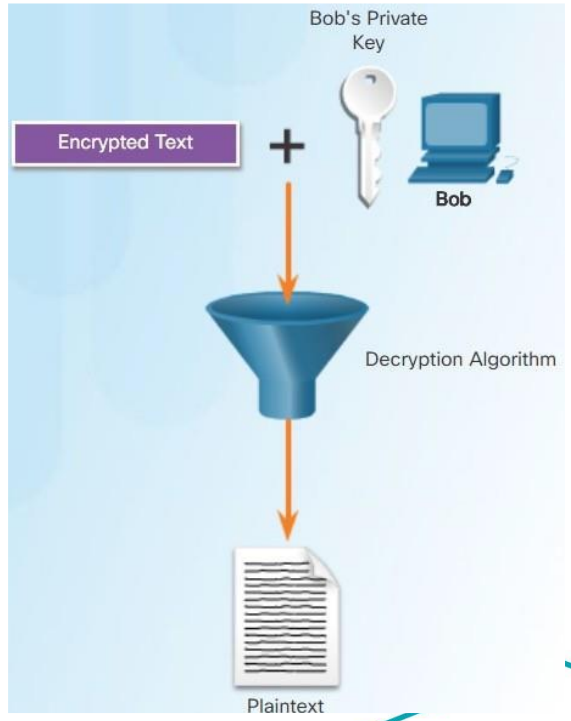
# Asymmetric Encryption - Integrity

- Combining the two asymmetric encryption processes provides message confidentiality, authentication, and integrity.



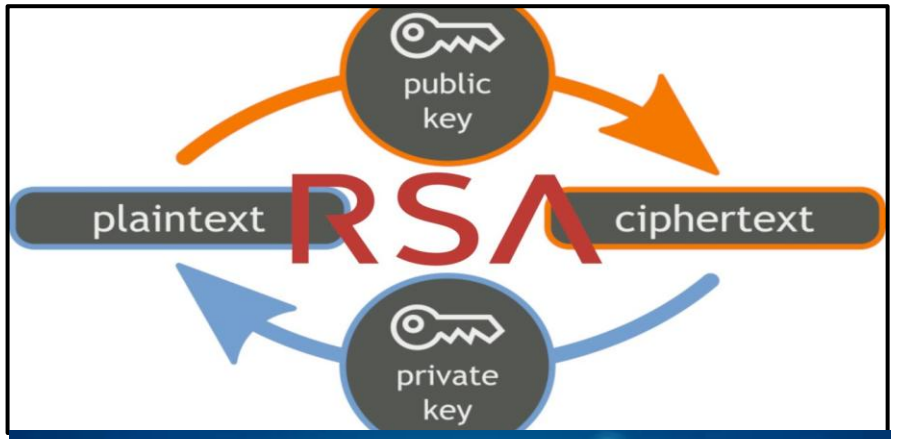




muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Types of Asymmetric Encryption

- **Rivest-Shamir-Adleman (RSA)**
  - RSA is one of the oldest and most widely used asymmetric encryption algorithms.
  - It relies on the mathematical properties of large prime numbers for security.
  - RSA is commonly used for secure communication, digital signatures, and key exchange protocols.
- **Elliptic Curve Cryptography (ECC)**
  - ECC is known for its efficiency and strong security, even with shorter key lengths compared to RSA.
  - It is especially suitable for resource-constrained environments such as mobile devices and IoT devices.
  - ECC is used in secure communications, digital signatures, and key exchange protocols like ECDH (Elliptic Curve Diffie-Hellman).



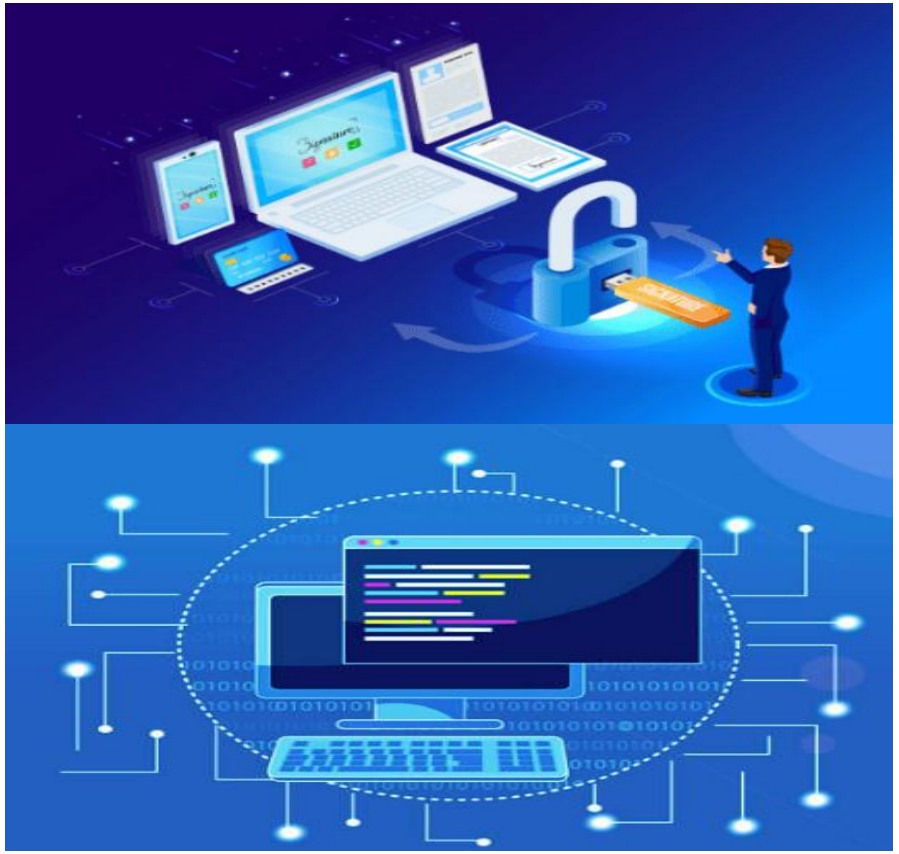



muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Types of Asymmetric Encryption (Contd.)

- **Digital Signature Algorithm (DSA)**
  - DSA is a widely used algorithm for creating digital signatures.
  - It is commonly employed in securing communications and authenticating the origin of digital documents.
  - DSA is often used in conjunction with hashing algorithms like SHA-256.
- **ElGamal**
  - ElGamal is an asymmetric encryption algorithm used for secure key exchange and digital signatures.
  - It is based on the Diffie-Hellman key exchange and provides semantic security.
  - ElGamal is less commonly used than RSA or ECC in practice.



muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Rivest–Shamir–Adleman (RSA) Example

## ❖ Key Generation

- Select Two Large Prime Numbers, p and q. These are kept secret.
  - **p = 61**
  - **q = 53**
- *Calculate n*: Compute n by multiplying p and q.
  - **n = p * q = 61 * 53 = 3233**
- *Calculate the totient (φ) of n*, which is the number of positive integers less than n that are coprime to n. For RSA, Φ(n) = (p - 1) * (q - 1).
  - **Φ(n) = (61 - 1) * (53 - 1) = 60 * 52 = 3120**
- *Choose a public exponent, e*, typically a small prime number, and ensure its coprime with Φ(n). A common choice is 65537 (2^16 + 1) because it has good cryptographic properties. Select a public exponent e, such as e = 17. (e is relatively prime to φ(n) = 3120)
  - **e = 17**
- *Calculate the private exponent, d,* which is the modular multiplicative inverse of e modulo Φ(n). You can use the extended Euclidean algorithm to find d. (Using the Extended Euclidean Algorithm):
  - **d ≡ 2753**




muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Rivest–Shamir–Adleman (RSA) Example (Contd.)

- **Key Pair**
  - Public Key: (n, e) -> (3233, 17)
  - Private Key: (n, d) -> (3233, 2753)
- **Encryption:**
  - To encrypt a message, M, using the recipient's public key (n, e):
  - Convert the message into an integer.
  - M = "HELLO" can be converted into its ASCII representation: H (72), E (69), L (76), L (76), O (79)
  - Encrypt the message using the recipient's public key: C ≡ M^e (mod n).
  - **C ≡ 72^17 (mod 3233) = 1733, C ≡ 69^17 (mod 3233) = 1702, C ≡ 76^17 (mod 3233) = 2358, C ≡ 76^17 (mod 3233) = 2358, C ≡ 79^17 (mod 3233) = 998.**
- **Decryption:**
  - To decrypt the ciphertext, C, using the recipient's private key (n, d):
  - Decrypt the ciphertext using the private key: M ≡ C^d (mod n).
  - **M ≡ 1733^2753 (mod 3233) = 72, M ≡ 1702^2753 (mod 3233) = 69, M ≡ 2358^2753 (mod 3233) = 76, M ≡ 2358^2753 (mod 3233) = 76, M ≡ 998^2753 (mod 3233) = 79.**
  - Convert the decrypted integer back into the original message.
  - **M = 72, 69, 76, 76, and 79 corresponds to the ASCII characters "H", "E", "L", "L", and "O".**




muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Digital Signature Algorithm (DSA) Example

## ❖ Key Generation

- **Select Parameters:**
  - Choose a prime number, p.
  - Choose a prime number, q, which is a divisor of (p-1).
  - Choose a number, g, such that g^q ≡ 1 (mod p).
  - **p = 107**
  - **q = 13**
  - **g = 2 (a common choice)**
- **Generate Private Key:**
  - Choose a private key, x, which is a random number between 1 and q-1.
  - **x = 6**
- **Compute Public Key:**
  - Calculate the public key, y, as y ≡ g^x (mod p).
  - **y ≡ 2^6 (mod 107) = 64**

## ❖ Key Pair

- Private Key: (x) -> (6)
- Public Key: (y, p, q, g) -> (64, 107, 13, 2)



muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Digital Signature Algorithm (DSA) Example (Contd.)

- **Signature Generation**
  - To sign a message, M, using the private key (x):
  - Choose a random number, k, between 1 and q-1.
  - **k = 10**
  - Calculate r ≡ (g^k mod p) mod q.
  - **r ≡ (2^10 mod 107) mod 13 = 9**
  - Calculate s ≡ k^(-1) * (H(M) + x * r) mod q, where H(M) is a cryptographic hash of the message.
  - H(M) = SHA-256(M) = 0x6c98aa3f2e91e07abf92ac201d7c55c7
  - **s ≡ 10^(-1) * (0x6c98aa3f2e91e07abf92ac201d7c55c7 + 6 * 9) mod 13 = 11**
- **Signature**
  - The DSA signature is the pair (r, s).
  - r = 9
  - s = 11



muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Digital Signature Algorithm (DSA) Example (Contd.)

- **Signature Verification**
  - To verify the signature (r, s) using the sender's public key (y, p, q, g):
  - Calculate w ≡ s^(-1) mod q.
  - **w ≡ 11^(-1) mod 13 = 6**
  - Calculate u1 ≡ (H(M) * w) mod q.
  - **u1 ≡ (0x6c98aa3f2e91e07abf92ac201d7c55c7 * 6) mod 13 = 10**
  - Calculate u2 ≡ (r * w) mod q.
  - **u2 ≡ (9 * 6) mod 13 = 11**
  - Calculate v ≡ ((g^u1 * y^u2) mod p) mod q.
  - **v ≡ ((2^10 * 64^11) mod 107) mod 13 = 9**
- **The signature is valid if v = r. If v = r, the signature is authentic.**

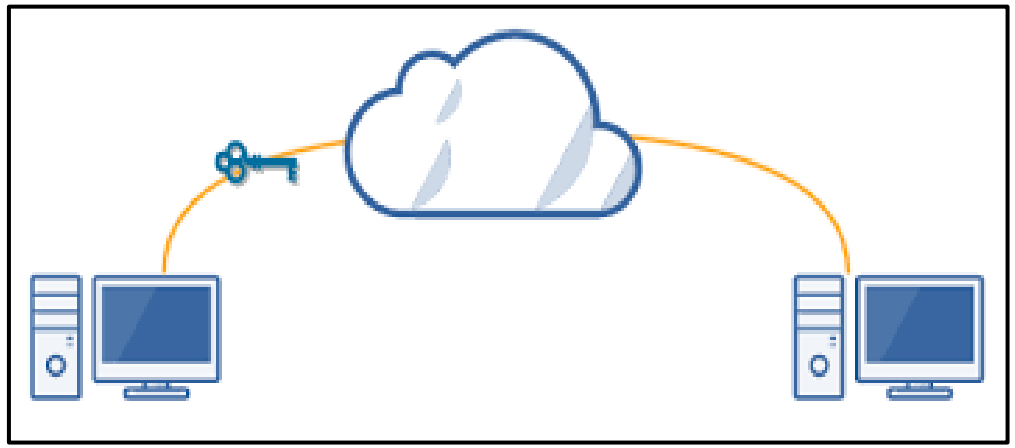


muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Key Exchange

- Prior to 1976 regardless of how good our encryption was designed, it still suffered from one major problem… how do we agree on keys between parties?
- Our only option was to somehow transfer a copy of the key using some out-of-band method.
- Diffie-Hellman(-Merkle) changed all this and published the first public key exchange protocol.
- DH allows two parties (Alice & Bob) to safely agree on a secret key in public even if an eavesdropper (Eve) overhears the entire conversation.
- Relies on the difficulty of solving discrete logarithms.
- Without a secure key exchange, encrypted communication can be easily compromised.



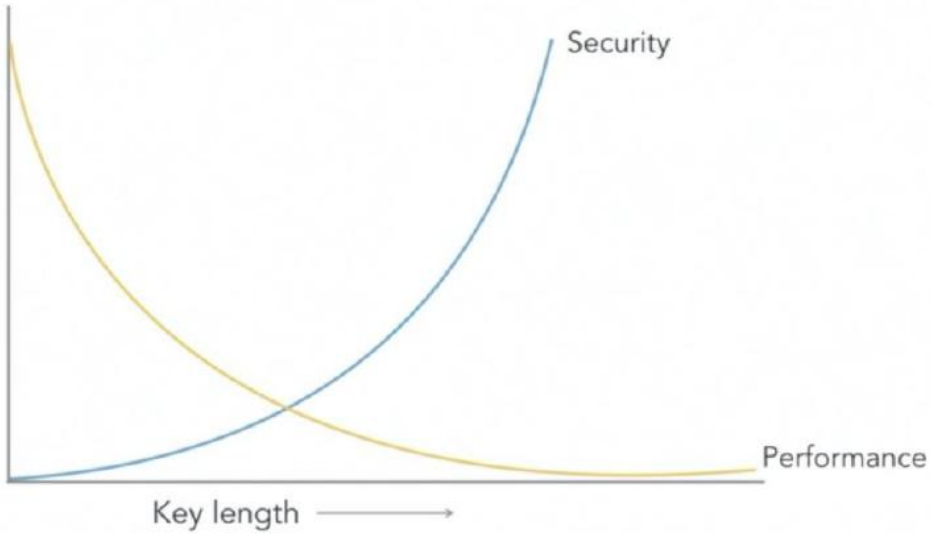
muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Choosing Your Keys

01010111 00001010 10110111 00000011 00101011
**40-bit key**

01100010 01110011 10110000 10100001 01011010 00011000 01001011 11110100
00110111 01101100 00011111 11110100 01111100 00101110 11000010 10111110
**128-bit key**




10110010 01100111 01010000 00101110 00011101 10101001 11111000 00010111
10100011 00010100 10110101 01100011 01010011 01111100 10110011 11010101
01000101 11110010 11010000 00100111 11000000 01110111 10101110 10111110
11000101 00001001 01101001 11001010 11000001 10001001 10000001 01010010
01010001 11111000 00100101 00100011 10101111 01111111 00011011 11011011
01111100 00100000 01011010 11011010 11110000 01100100 00111010 00000100
11010000 01110011 10110111 00001110 11001001 00000100 01100010 00010001
11011111 11011111 11110000 11110001 10001010 10000111 00010100 01011101
01110000 01001111 11001110 11000111 01101001 01100000 00110111 10101000
10111101 11000101 11100111 01111100 00111010 00101011 10110000 10111111
01100101 01111100 11000101 00010110 10110100 01100010 10011110 11101010
10110011 00000001 00011000 11110011 10000010 10010010 11100111 11001110
10100100 11101101 10110000 10011000 01100110 11010011 11011100 10011110
11000001 10100101 11010101 01011100 11110101 11100010 01001011 10011001
10010000 00100101 01111000 10000111 10101011 01110000 10001100 01001010
11001110 11001101 01111110 01111101 00100110 11010110 00011001 11101010
**1024-bit key**

muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Pairwise Shared Keys

- A pairwise shared key is a secure key only used by 2 parties to communicate with each other.
- That means every party has a different key from any other party.
- This works with a small number of people otherwise it gets complex due to the large number of different keys.



**Example:** Consider 4 people: Alice, Bob, Claire and Dave.

- Alice has a shared key with each of Bob, Claire, and Dave.
- Bob has a shared key with Claire and Dave.
- Claire has a shared key with Dave.
- For 4 people, 6 keys are needed. For 100 people, we would need almost 5 thousand keys.

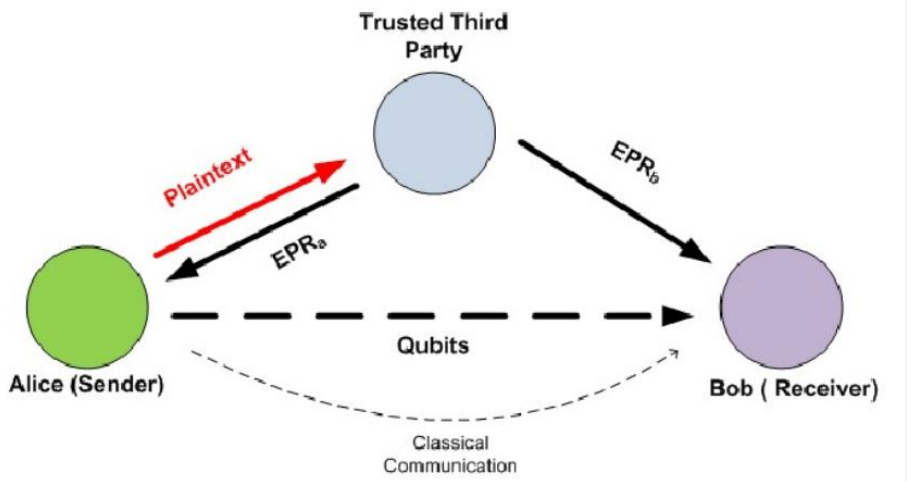
muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Trusted Third Party (TTP)

A trusted third party (TTP) has a shared secret with each individual.

- Assume 2 parties A, B in the network and a trusted third party TTP has a secret key to each party:
  one secret key $k_A$ to A and one secret key $k_B$ to B.
- When A and B want to communicate the protocol is:
  1. A sends a request to TTP for communication with B.
  2. TTP generates a random key $k_{AB} \in \{0, 1\}^n$
  3. TTP sends A the encrypted key $k_{AB}$ concatenated with B's name (user ID) with the shared key $k_A \in \{0, 1\}^n$ and sends B the encrypted key $k_{AB}$ concatenated with A's name (user ID) with the shared key $k_B \in \{0, 1\}^n$.
  4. A and B can communicate with the key $k_{AB}$.




The problems with a trusted third party are:

1. TTP can read all messages between A and B because TTP generates the key $k_{AB}$, so can read every intercepted message over the insecure channel between A and B.
2. TTP can impersonate every customer. TTP can generate a fake conversation, and make it seem like A is communicating with B.
3. An attacker could steal $k_{AB}$ (depending on encryption and modes of operation used).

muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Types of Asymmetric Encryption (Key Exchange)

## ❖ Diffie-Hellman (DH)

- Diffie-Hellman is primarily a key exchange algorithm rather than an encryption or decryption algorithm.
- It allows two parties to agree on a shared secret key over an insecure channel without directly sharing the key.
- Variants of Diffie-Hellman, such as Ephemeral Diffie-Hellman (DHE) and Elliptic Curve Diffie-Hellman (ECDHE), are used in SSL/TLS for securing web communications.

## ❖ Post-Quantum Cryptography (PQC)

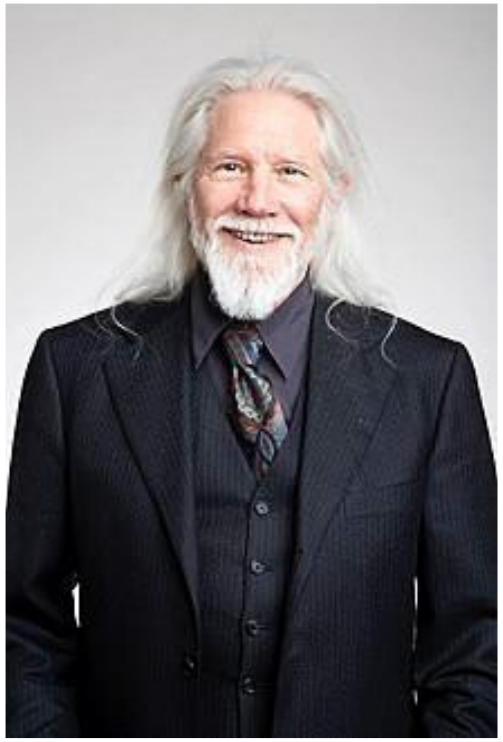
- Most PQC algorithms will use a larger key size, with the advent of quantum computers.
- Post-quantum algorithms are designed to resist attacks from quantum computers.
- If a large key size is required, changes have to be made to various Internet protocols like Transfer Layer Security (TLS) protocol or the Internet Key Exchange.



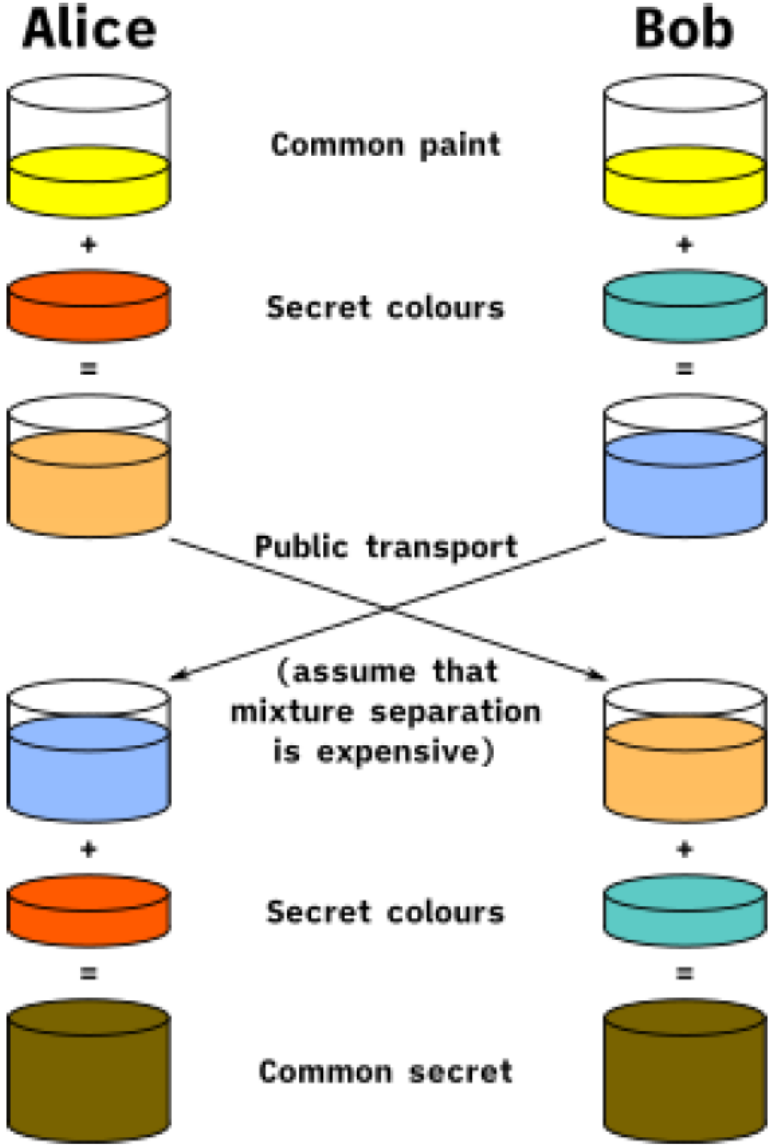
muhammad.arshad@tudublin.ie

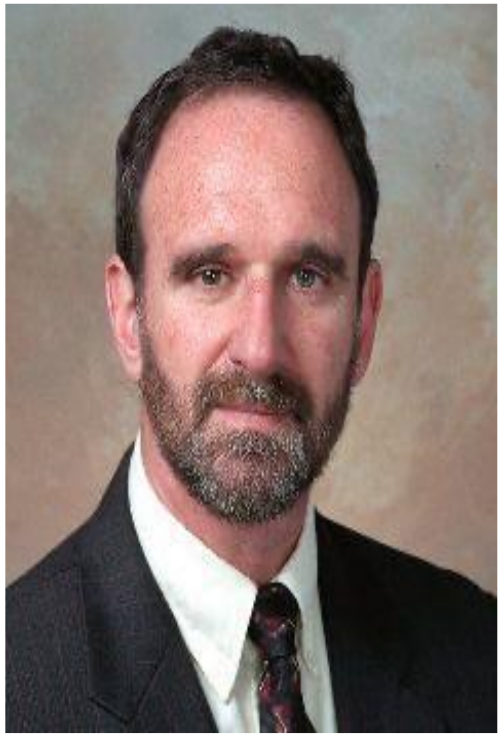
OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Diffie-Hellman Key Exchange



**Whitfield Diffie**



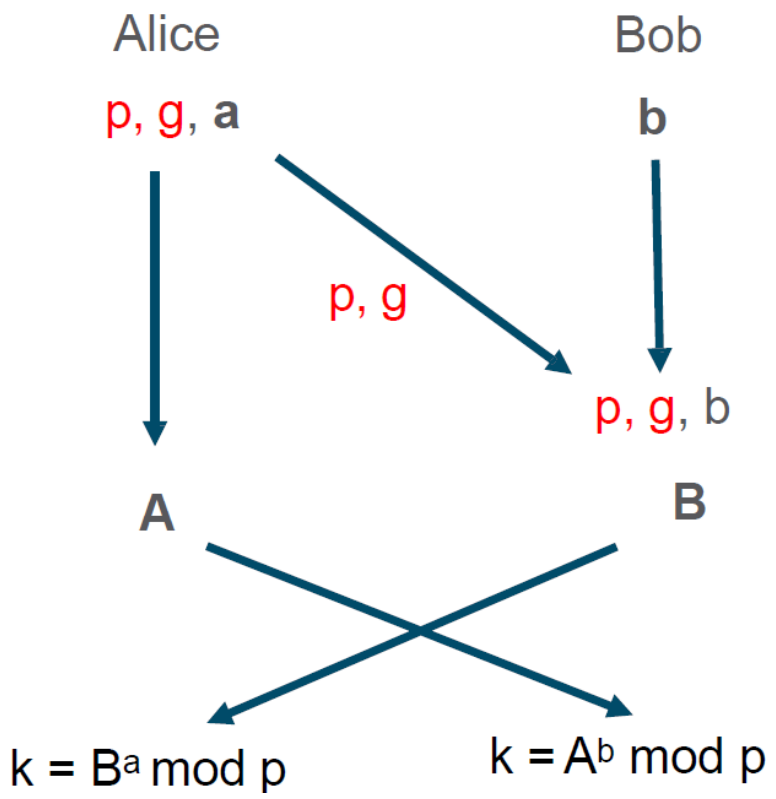
**Martin Hellman**

muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
TU DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Diffie-Hellman Key Exchange (DHKE)

- The Diffie Hellman Key Exchange (DHKE) allows 2 parties without any prior agreement to be able to establish a shared secret key. The protocol for the DHKE with two parties A and B is:
  - Alice picks some values p (large prime number) and g (the primitive root of p called the generator) and sends them to "B".
  - Alice selects a random value a $\in \{0, 1\}^n$ and Bob selects a random value b $\in \{0, 1\}^n$
  - Alice computes **A** = $g^a$ mod p
  - Bob computes **B** = $g^b$ mod p
  - Alice and Bob exchange their computed values
  - Alice computes the key k = $B^a$ mod p
  - Bob computes the key k = $A^b$ mod p

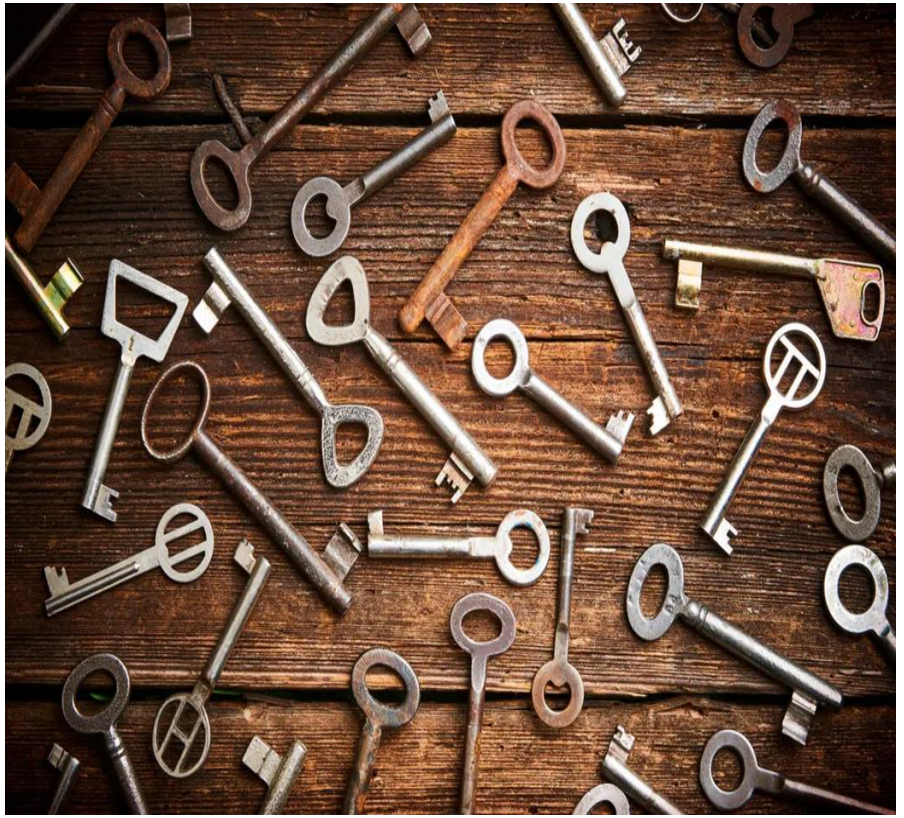



muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Diffie-Hellman Key Exchange Example

- **Initialization**
  - Alice and Bob agree on public parameters
    - Prime number (p) = 23
    - Primitive root modulo g = 9
- **Key Generation**
  - Alice chooses her private key (a) = 4 and computes her public key (A)
    - A = g^a mod p
    - A = 9^4 mod 23
    - A = 6 (This is Alice's public key)
  - Bob chooses his private key (b) = 3 and computes his public key (B)
    - B = g^b mod p
    - B = 9^3 mod 23
    - B = 16 (This is Bob's public key)
- **Key Exchange**
  - Alice sends her public key (A = 6) to Bob.
  - Bob sends his public key (B = 16) to Alice.



muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Diffie-Hellman Key Exchange Example (Contd.)

## ❖ Shared Secret Calculation

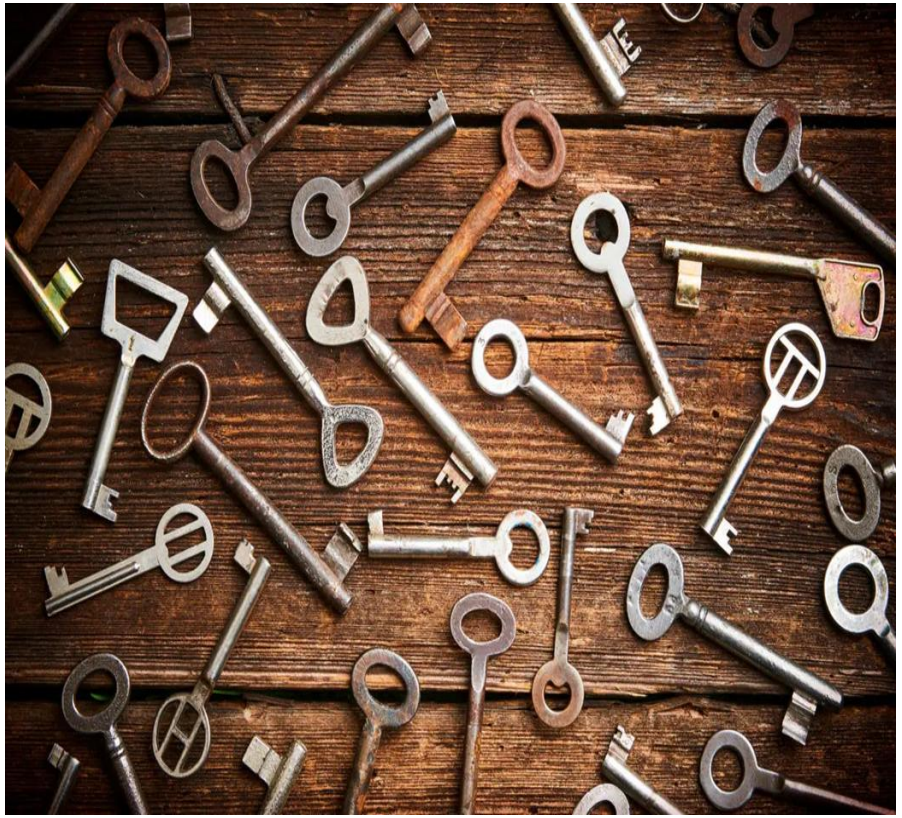
- ➢ Alice calculates the shared secret key (S) using Bob's public key:
  - S = B^a mod p
  - S = 16^4 mod 23
  - S = 9 (This is Alice's shared secret key)
- ➢ Bob calculates the shared secret key (S) using Alice's public key:
  - S = A^b mod p
  - S = 6^3 mod 23
  - S = 9 (This is Bob's shared secret key)

## ❖ Secrecy of the Shared Secret

- ➢ Now, Alice and Bob both have the same shared secret key (S = 9), which they can use for secure communication.
- ➢ Even if an eavesdropper intercepted their public keys (A and B), it would be extremely difficult to compute the shared secret key without knowing Alice's private key (a) or Bob's private key (b).

## ❖ Key Use

- ➢ Alice and Bob can use their shared secret key (S) to encrypt and decrypt their messages.
- ➢ They can now communicate securely, knowing that their shared secret key is unknown to potential eavesdroppers



muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Another Diffie-Hellman Example

| Alice | | Bob | | Eve | |
|---|---|---|---|---|---|
| **Known** | **Unknown** | **Known** | **Unknown** | **Known** | **Unknown** |
| $p = 23$ | | $p = 23$ | | $p = 23$ | |
| $g = 5$ | | $g = 5$ | | $g = 5$ | |
| $\mathbf{a = 6}$ | $\mathbf{b}$ | $\mathbf{b = 15}$ | $\mathbf{a}$ | | $\mathbf{a}$, $\mathbf{b}$ |
| $A = 5^a \bmod 23$ | | $B = 5^b \bmod 23$ | | | |
| $A = 5^6 \bmod 23 = 8$ | | $B = 5^{15} \bmod 23 = 19$ | | | |
| $\mathbf{B = 19}$ | | $\mathbf{A = 8}$ | | $A = 8, B = 19$ | |
| $\mathbf{s} = B^a \bmod 23$ | | $\mathbf{s} = A^b \bmod 23$ | | | |
| $\mathbf{s} = 19^6 \bmod 23 = \mathbf{2}$ | | $\mathbf{s} = 8^{15} \bmod 23 = \mathbf{2}$ | | | $\mathbf{s}$ |

muhammad.arshad@tudublin.ie

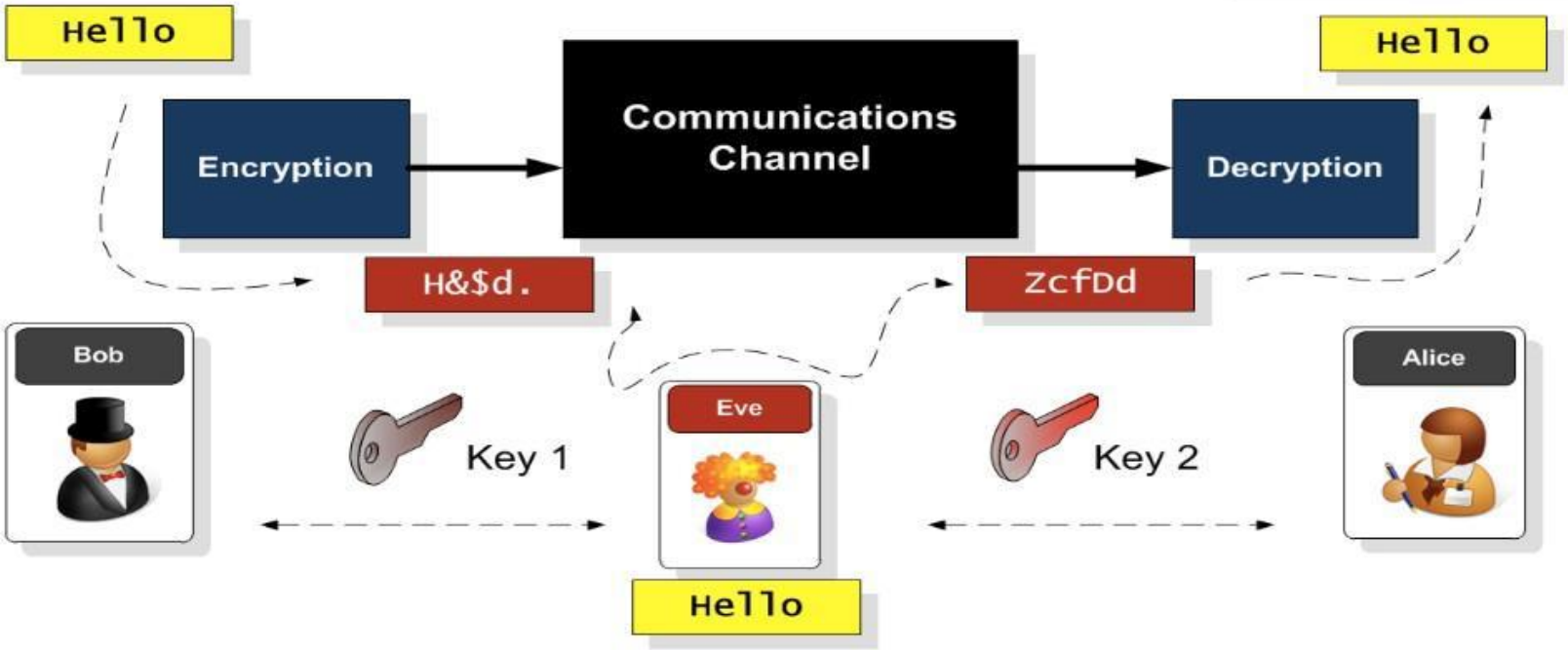
OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
TU DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Man-in-the-Middle Attack

Diffie-Hellman suffers from a man-in-the-middle attack, where Eve negotiates for each side, and creates two encryption channels

**Man-in-the-middle**

Diffie-Hellman suffers from Eve intercepting the key interchange, so that Bob thinks he's talking to Alice for the key exchange.

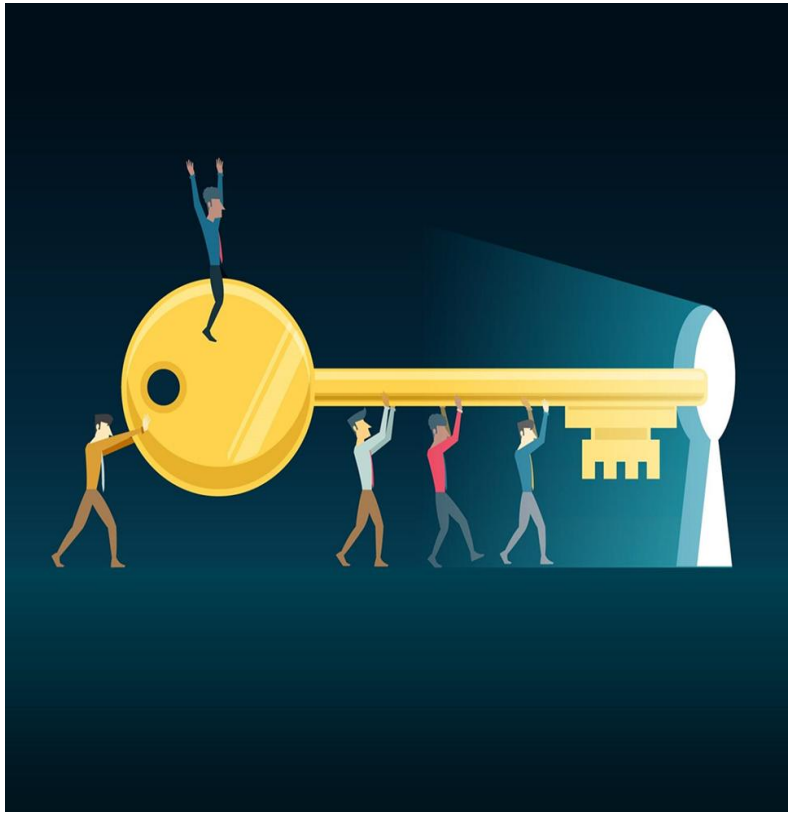



muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
TU DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Forward Secrecy or Perfect Forward Secrecy

- Crucial security features and specific key agreement protocols in the context of secure communication over the Internet.
- It ensures that even if a long-term private key is compromised, it will not expose the confidentiality of past communications.
  - **Key Generation**
    - Generate a session key (temporary encryption key) for encrypting and decrypting messages during that specific session.
  - **Perfect Forward Secrecy**
    - A new session key is generated for each session.
    - An attacker cannot decrypt past sessions and even knows the long-term private key.
    - because those sessions were encrypted with different, session-specific keys.
  - **Regular Key Rotation**
    - Forward Secrecy often involves regularly rotating the session keys.
    - further reducing the window of opportunity for an attacker to gain access to useful information.
- Forward Secrecy is widely used in secure communication protocols like HTTPS (used for secure web browsing).



muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Ephemeral Keys

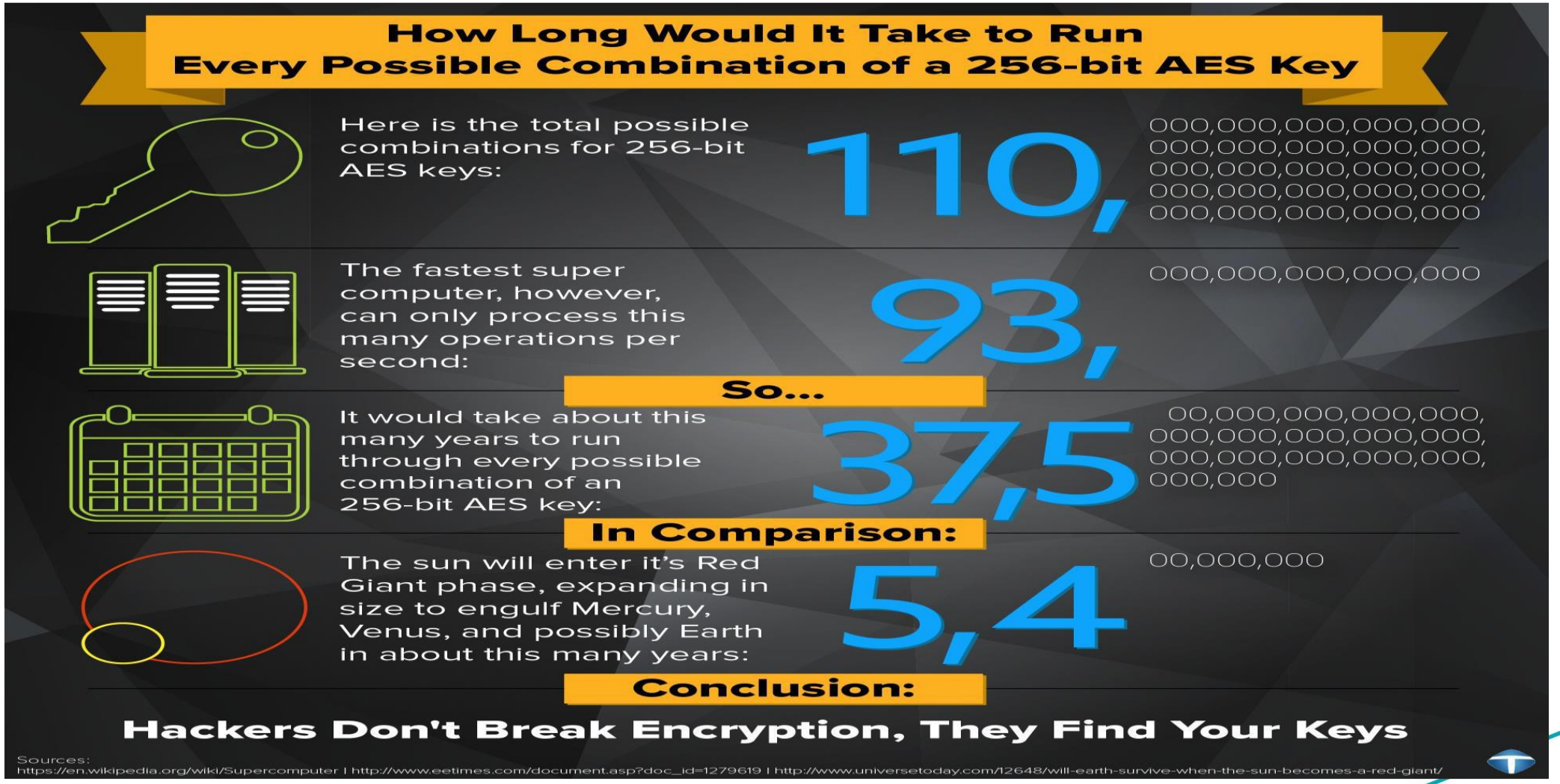
- Ephemeral keys are used for short-term, single-purpose operations and are generated on the fly for each session or transaction.
- They are not reused and have a limited lifetime.
- Diffie-Hellman Ephemeral (DHE) or Elliptic Curve Diffie-Hellman Ephemeral (ECDHE) are used to establish a shared secret between two parties without transmitting the secret itself.
- In protocols like TLS, ephemeral keys are often used for securing HTTPS connections.
- Blockchain protocols generate ephemeral keys for transactions, ensuring that each transaction has its unique key, improving privacy and security.
- The main advantage of ephemeral keys is that they provide an additional layer of security.
- They are short-lived and change frequently, making it harder for attackers to compromise the communication.



muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Difficult to Break Encryption




muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
TU DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Key Management

- Key management is administering the full lifecycle of cryptographic keys.
- This includes the generation of keys, their use, how they are stored, archived, and deleted.
- Also, protection of the encryption keys includes limiting access to the keys physically, logically, and through user/role access.

***Poor and key management may easily compromise strong algorithms***

Section 5 of NIST.SP.800 57pt1r5

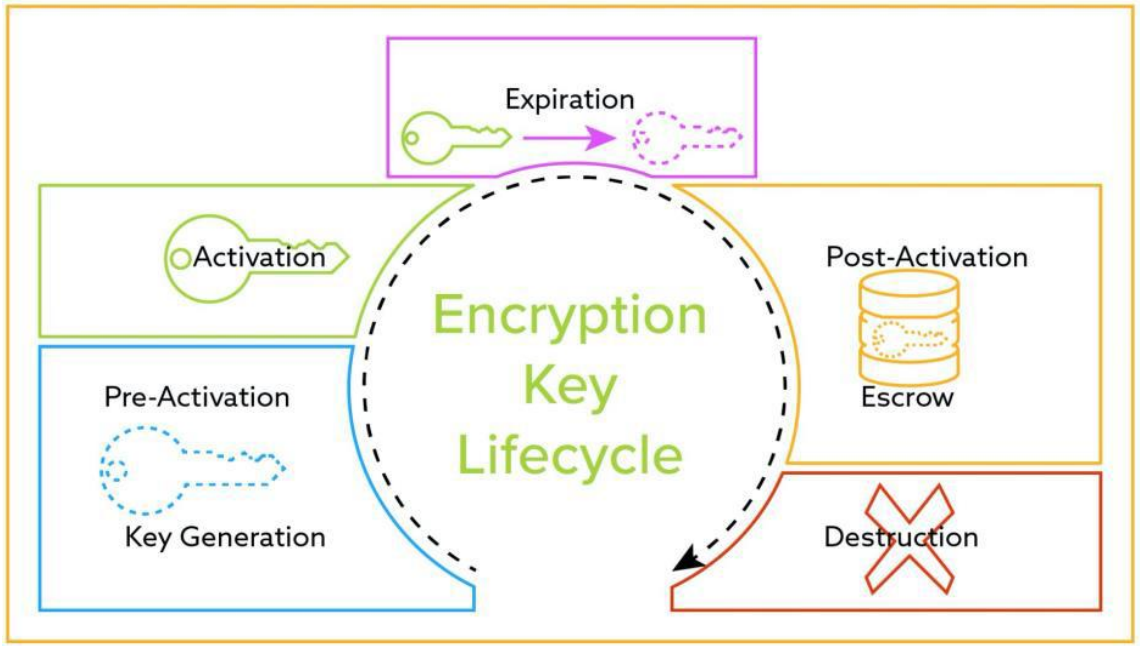
- Classifies the different types of keys and other cryptographic information according to their uses;
- Discusses crypto periods and suggests appropriate crypto periods for each key type;
- Provides recommendations and requirements for other keying material;
- Introduces assurance of domain parameter validity, public key validity, and private key possession;
- Discusses the implications of the compromise of keying material;
- And guides the selection, implementation, and replacement of cryptographic algorithms and key sizes according to their security strengths.

muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
TU DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Key Management (Contd.)

- Your encryption keys are only as good as the security you use to protect them.
- There is an entire physical and digital cryptosystem that must be accounted for, as well as each key's full lifecycle.
- A robust encryption key management system and policies include:
  - Key lifecycle: key generation, pre-activation, activation, expiration, post-activation, escrow, and destruction
  - Physical access to the key server(s)
  - Logical access to the key server(s)
  - User/Role access to the encryption keys;

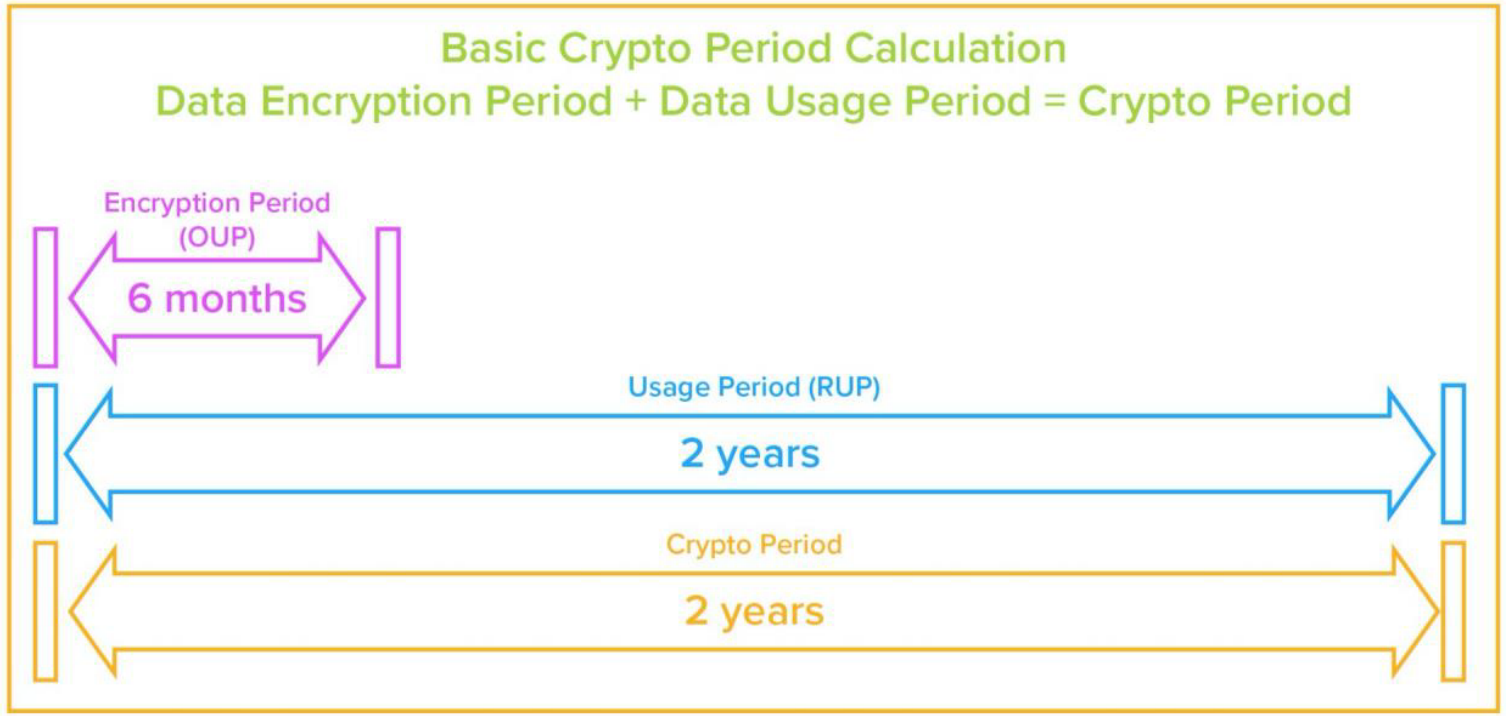



muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Key Management Example

- let's say that a database is encrypted and for the next 6 months items are added to it. Then:
  - the originator usage period OUP is 6 months
  - For 2 years the database is also viewed by authorized users. Then:
  - the recipient usage period RUP is 2 years (and completely overlaps with the OUP)
- therefore, the crypto period would equal 2 years and the encryption key would need to be active during that time.

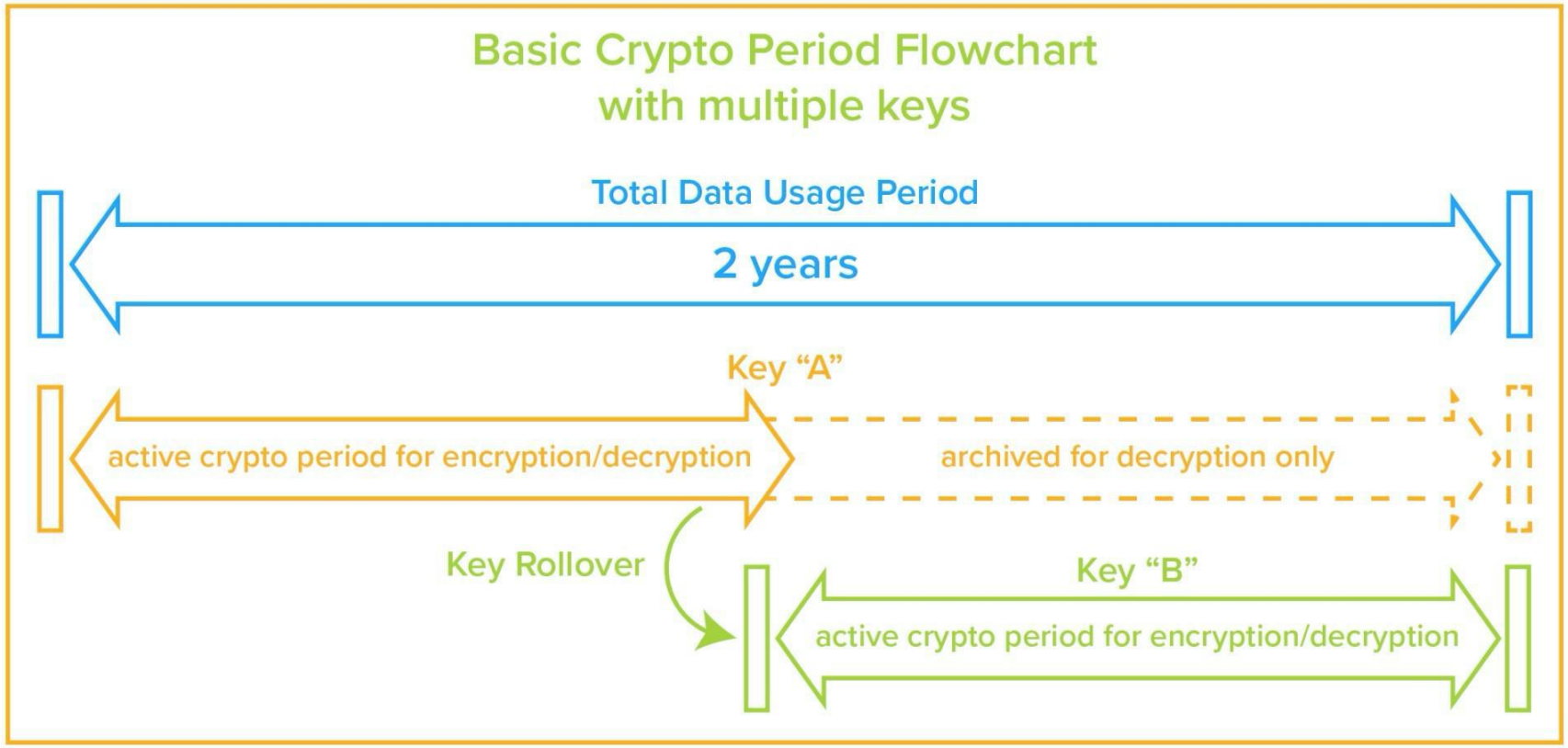



muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Key Management Example (Contd.)

- Given this, your encryption key may have an active life shorter than an authorized user's access to the data. This means that you will need to archive de-activated keys and use them only for decryption Once the data has been decrypted by the old key, it will be encrypted by the new key, and over time the old key will no longer be used to encrypt/decrypt data and can be deleted.




muhammad.arshad@tudublin.ie

# Suggested Crypto-Periods for Key Types

| Key Type | Cryptoperiod | |
|---|---|---|
| | Originator-Usage Period (OUP) | Recipient-Usage Period |
| 1. Private Signature Key | 1 to 3 years | – |
| 2. Public Signature-Verification Key | Several years (depends on key size) | |
| 3. Symmetric Authentication Key | ≤ 2 years | ≤ OUP + 3 years |
| 4. Private Authentication Key | 1 to 2 years | |
| 5. Public Authentication Key | 1 to 2 years | |
| 6. Symmetric Data Encryption Keys | ≤ 2 years | ≤ OUP + 3 years |
| 7. Symmetric Key-Wrapping Key | ≤ 2 years | ≤ OUP + 3 years |
| 8. Symmetric RBG Keys | See SP 800-90 | – |
| 9. Symmetric Master Key/Key Derivation Key | About 1 year | – |
| 10. Private Key Transport Key | ≤ 2 years[61] | |
| 11. Public Key Transport Key | 1 to 2 years | |
| 12. Symmetric Key Agreement Key | 1 to 2 years[62] | |
| 13. Private Static Key Agreement Key | 1 to 2 years[63] | |
| 14. Public Static Key Agreement Key | 1 to 2 years | |

muhammad.arshad@tudublin.ie

OLLSCOIL TEICNEOLAÍOCHTA BHAILE ÁTHA CLIATH
DUBLIN
TECHNOLOGICAL UNIVERSITY DUBLIN

# Short Quiz

- **In public key encryption (asymmetric encryption) to secure message confidentiality:**
  1. encryption is done by a private key and decryption is done by a public key.
  2. encryption is done by public key and decryption is done by private key.
  3. both the keys used to encrypt and decrypt the data are public.
  4. both the keys used to encrypt and decrypt the data are private.

  - encryption is done by public key and decryption is done by private key.

- **A commercial website uses asymmetric encryption where there is one private key for the server and the corresponding public key is made available to the customers. This ensures:**
  1. authenticity of the customer.
  2. authenticity of the website.
  3. confidentiality of messages from the website hosting organization to customers.
  4. Non-repudiation from customer.

  - authenticity of the website.

- **Which of the following options increases the cost of cryptography?**
  1. Use of symmetric technique rather than asymmetric.
  2. Use of a long asymmetric key rather than a short one.
  3. Only the hash is encrypted rather than a full message.
  4. Use of a short asymmetric key rather than a long one.

  - Use of a long asymmetric key rather than a short one.

muhammad.arshad@tudublin.ie

# Practical Exercise

- **Week 5 - 16th Oct**
  - Attempt **Lab 5 - Symmetric Key Encryption, Lab 9 - Key Exchange,** and **Lab 10 - Public Key** Worksheets during the lab sessions
  - CryptoHack.org website - Complete block Cipher challenges **(AES Section)**, Complete **RSA (Starter challenges),** & **Complete Diffie-Hellman (Starter challenges)**
  - Read **Chapters 4 & 5 - Public Key & Key Exchange**- Cryptography by William Buchanan
  - **Assignment 2 –** Lab 6 **Encrypted Image (Challenge Lab)** due on 18th October
  - **Test 1** on **23rd October** during the lab session

muhammad.arshad@tudublin.ie